Enterprise-Grade Threat Detection & Automated Response Platform

Incident Response Report: Simulated Insider Threat & Full Cyber Kill Chain Exercise

Prepared by	Younes Belayouni
Platform	Wazuh SIEM / XDR (Manager + Agent Deployment)
Environment	VMware Workstation — Manager, Agent, and Attacker (Kali) VMs
Scenario Type	Insider Threat / Full Cyber Kill Chain Simulation
Classification	Internal — Cybersecurity Engineering Coursework

Abstract

This report documents a controlled offensive-security exercise performed against a self-hosted Wazuh SIEM/XDR deployment, simulating a realistic insider threat scenario mapped to a full cyber kill chain. A low-privilege user account (**ag2**) was used to gain remote access to a monitored endpoint, escalate privileges through a deliberately introduced sudo misconfiguration, establish persistence via a scheduled task, exfiltrate a simulated sensitive data file, and attempt to erase forensic evidence. Each stage of the exercise was cross-referenced against Wazuh's alerting pipeline and dashboard to evaluate the platform's detection coverage. The exercise validated that Wazuh correctly identified authentication events, privilege escalation, and file-level activity through its default rule set, while also surfacing realistic detection gaps around encrypted data transfer — findings that are directly relevant to real-world SOC operations.

Table of Contents

1. Introduction
2. Scenario Overview: Insider Threat / Full Kill Chain Simulation
3. Environment and Tools
4. Attack Narrative and Evidence
   4.1 Preparation — Staging the Target Asset
   4.2 Initial Access and Lateral Movement
   4.3 Privilege Escalation — Reconnaissance
   4.4 Privilege Escalation — Exploitation
   4.5 Detection Confirmation (CLI)
   4.6 Persistence
   4.7 Data Exfiltration
   4.8 Defense Evasion — Anti-Forensics Attempt
   4.9 Detection via the Wazuh Dashboard
5. MITRE ATT&CK Technique Mapping
6. Results and Evaluation
7. Detection Gaps and Recommendations
8. Conclusion

References

1. Introduction

Following the deployment of a Wazuh-based mini Security Operations Center (SOC) — comprising a central manager, a monitored Ubuntu endpoint running a vulnerable web application, and dedicated user accounts of varying privilege — this report documents a hands-on offensive exercise designed to validate the platform's end-to-end detection capability. Rather than testing isolated attack techniques in a disconnected manner, this exercise chains multiple attacker behaviors into a single, realistic incident, allowing the resulting telemetry to be analyzed as a coherent timeline rather than a set of unrelated alerts.

The scenario was deliberately framed as an **insider threat**: an attacker who has already obtained valid, low-privilege credentials for the environment (representing either a compromised employee account or credentials harvested through an earlier attack stage) and uses that foothold to escalate privileges, persist, and exfiltrate sensitive data.

2. Scenario Overview: Insider Threat / Full Kill Chain Simulation

The exercise follows the structure of a classic cyber kill chain, adapted to an insider-access starting point. Each stage below is mapped to a corresponding MITRE ATT&CK tactic and was executed against the lab environment, then independently verified against Wazuh's alert log and dashboard.

Stage	Objective	MITRE Tactic
1. Preparation	Stage a simulated sensitive data asset on the target	—
2. Initial Access / Lateral Movement	Authenticate to the endpoint as a low-privilege user (ag2)	Initial Access / Lateral Movement
3. Privilege Escalation (Recon)	Enumerate SUID binaries and cron jobs for escalation paths	Discovery
4. Privilege Escalation (Exploit)	Exploit a sudo misconfiguration to obtain root	Privilege Escalation
5. Persistence	Install a scheduled cron-based callback	Persistence
6. Exfiltration	Copy the sensitive file to the attacker machine via SCP	Exfiltration
7. Defense Evasion	Clear shell history and truncate authentication logs	Defense Evasion

3. Environment and Tools

Role	Machine	Notes
Wazuh Manager	ubuntu2004 (192.168.130.149)	Manager, indexer, and dashboard (all-in-one install)
Monitored Endpoint (Agent)	wazuh-agent1 (192.168.130.183)	Ubuntu 20.04, Wazuh agent, hosts DVWA
Low-Privilege Account	ag2	Simulated insider / compromised credential
Administrative Account	ag1	Legitimate local administrator, used for baseline config
Attacker Machine	Kali Linux (192.168.130.129)	Used for SSH access, SCP exfiltration, and dashboard review

4. Attack Narrative and Evidence

4.1 Preparation — Staging the Target Asset

To give the exercise a concrete exfiltration objective, a simulated sensitive data file (`customer_data.csv`) containing mock customer records was created under the `ag2` account's home directory on the monitored endpoint, representing a business-critical asset an insider might target.

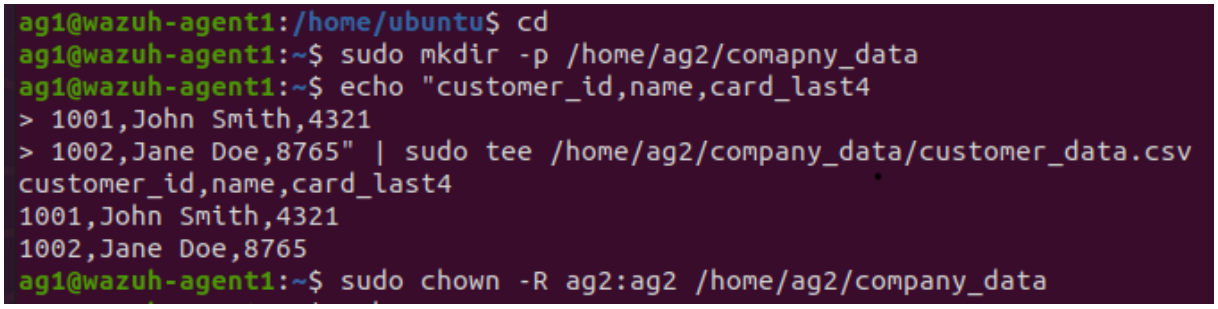


Figure 1. *Creation of the simulated sensitive asset (customer_data.csv) on the agent VM, with ownership assigned to the ag2 account.*

4.2 Initial Access and Lateral Movement

Using the `ag2` credentials — representing either a reused or otherwise obtained valid account — a remote SSH session was established from the attacker machine to the monitored endpoint. This step corresponds to MITRE ATT&CK **T1078 (Valid Accounts)** and demonstrates lateral movement into the environment.

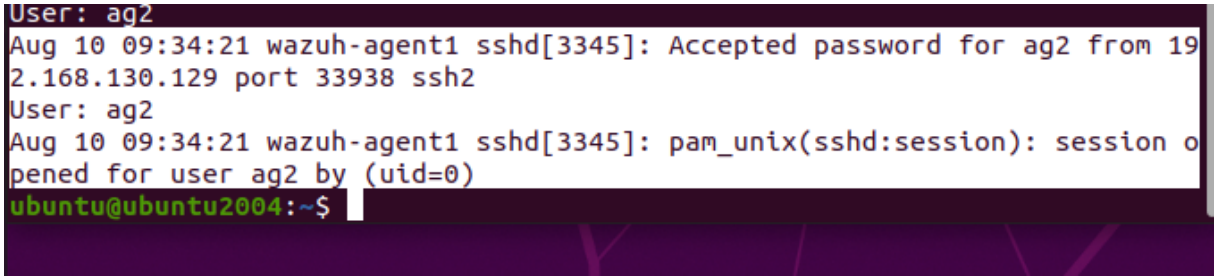


Figure 2. *Authentication log on the endpoint recording the successful SSH session for ag2, originating from the attacker machine at 192.168.130.129.*

4.3 Privilege Escalation — Reconnaissance

Prior to attempting escalation, standard local enumeration was performed to identify viable paths: a search for SUID-bit binaries and inspection of scheduled cron jobs. Both correspond to MITRE ATT&CK **Discovery** tactics and are standard practice before any escalation attempt.

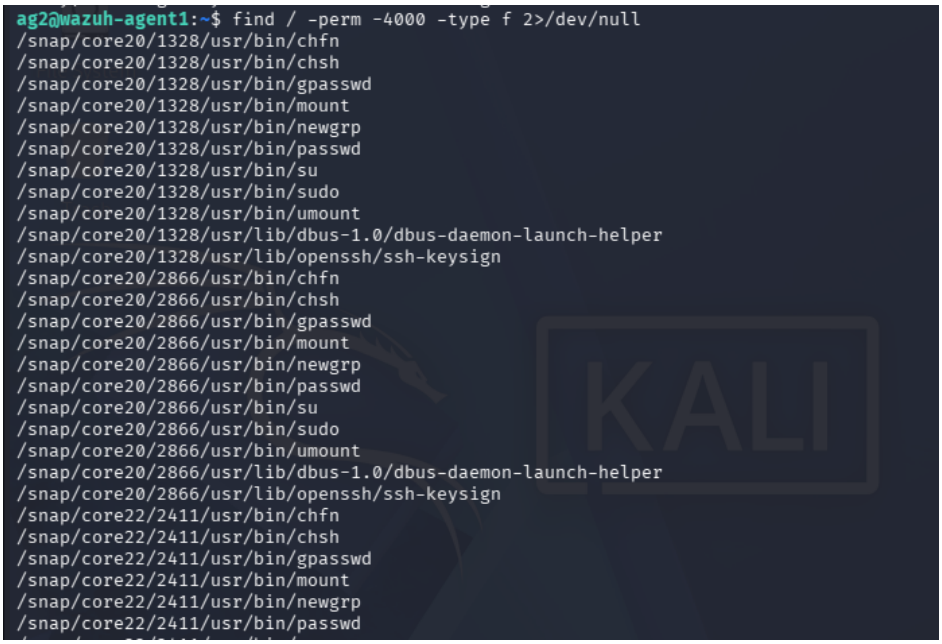


Figure 3. *Enumeration of SUID-bit binaries on the endpoint via find / -perm -4000, searching for misconfigured executables that could enable privilege escalation.*

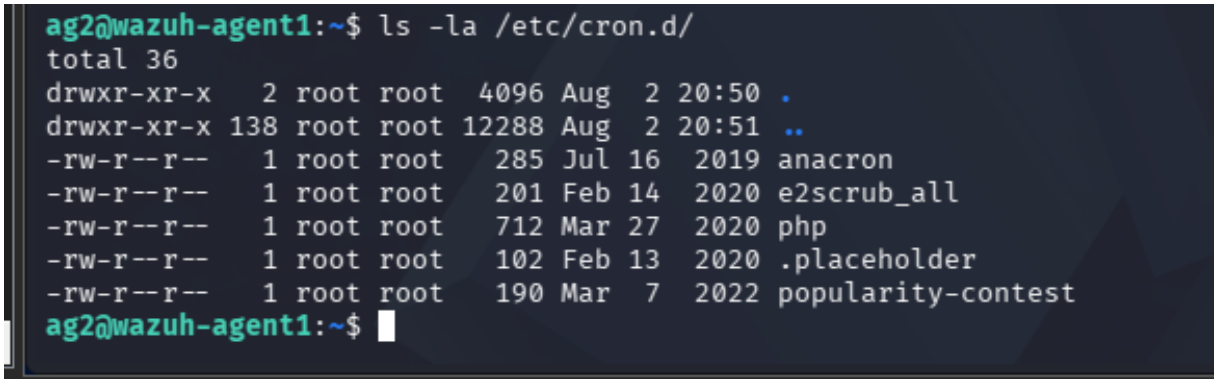


Figure 4. *Inspection of scheduled tasks under /etc/cron.d/ as part of the same reconnaissance phase.*

4.4 Privilege Escalation — Exploitation

A deliberate sudo misconfiguration was introduced (granting `ag2` passwordless execution of `/bin/bash`) to model a realistic misconfiguration an attacker could discover and abuse. This was then exploited to obtain a fully privileged root shell, corresponding to MITRE ATT&CK **T1548.003 (Sudo and Sudo Caching)**.

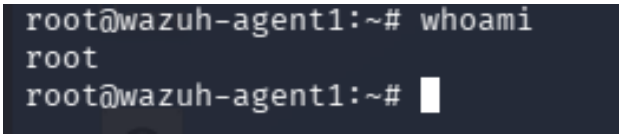


Figure 5. *Confirmation of successful privilege escalation: the shell now runs as the root user.*

4.5 Detection Confirmation (Command Line)

Immediately following the escalation, the manager's alert log was queried to confirm Wazuh's default rule set correctly flagged the event. Rule **5402** ("Successful sudo to ROOT executed") fired as expected, providing high-confidence, out-of-the-box detection of this stage without any custom rule authoring required.

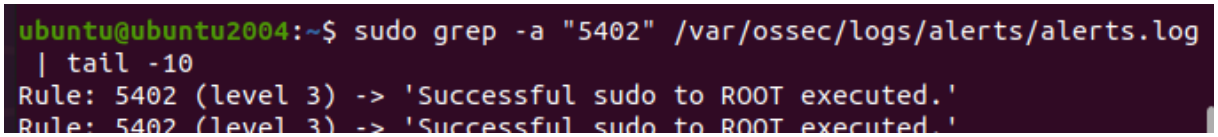


Figure 6. *Wazuh manager alert log confirming detection of the privilege escalation event (Rule 5402, level 3 — Successful sudo to ROOT executed).*

4.6 Persistence

With root access secured, a persistence mechanism was installed by appending a scheduled cron entry that periodically invokes an outbound callback, simulating a command-and-control beacon. The endpoint's File Integrity Monitoring (FIM) configuration was extended to explicitly cover `/etc/crontab` and `/root/.ssh`, ensuring modifications to these high-value paths generate alerts. This stage corresponds to MITRE ATT&CK **T1053.003 (Scheduled Task/Job: Cron)**.

4.7 Data Exfiltration

The simulated sensitive file was transferred from the compromised endpoint to the attacker machine using SCP, representing the exercise's exfiltration objective and mapping to MITRE ATT&CK **T1041 (Exfiltration**

Over C2 Channel).

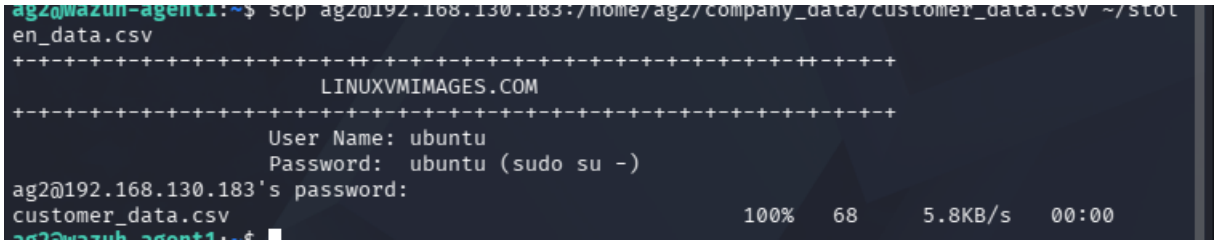


Figure 7. *SCP transfer of customer_data.csv from the compromised endpoint to the attacker machine, completed successfully (100%, 68 bytes).*

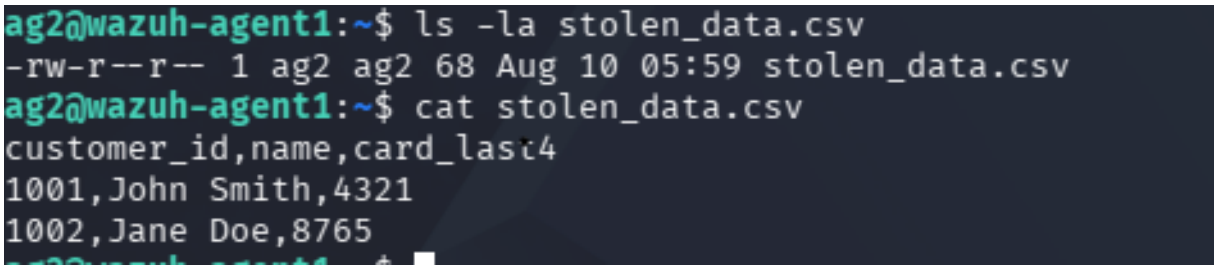


Figure 8. *Verification on the attacker machine that the exfiltrated file was received intact and its contents are readable.*

4.8 Defense Evasion — Anti-Forensics Attempt

As a final stage, an attempt was made to erase forensic evidence of the intrusion by clearing the shell command history and truncating the local authentication log (`/var/log/auth.log`). This models MITRE ATT&CK **T1070 (Indicator Removal)** and is one of the most reliably detected behaviors in Wazuh's default rule set, as log truncation is a well-signatured attacker pattern.

4.9 Detection via the Wazuh Dashboard

To validate that the full attack chain was not only logged but also usable by a SOC analyst working from the graphical interface, the same events were independently investigated through the Wazuh dashboard's Threat Hunting module, filtered by the compromised account (`ag2`).

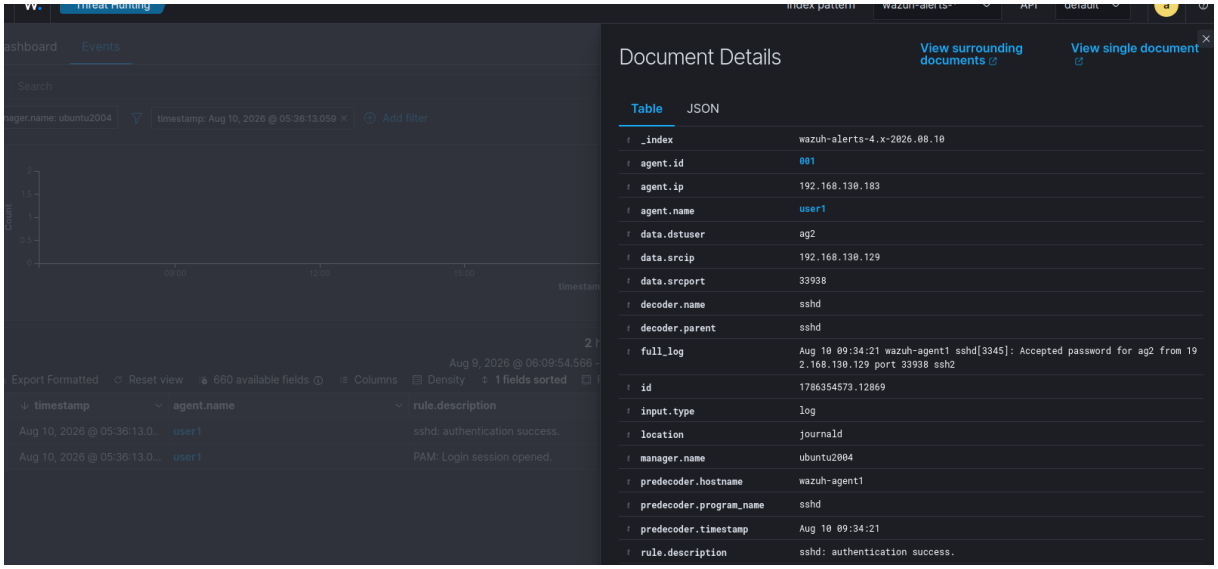


Figure 9. *Wazuh dashboard event detail confirming the SSH lateral-movement event for ag2, including source IP, decoder, and full raw log entry — matching the CLI evidence captured in Figure 2.*

```
Aug 10 09:33:04 wazuh-agent1 su[3338]: pam_unix(su:session): session opened for user ag1 by ag2(uid=1002)
Src IP: 192.168.130.129
User: ag2
Aug 10 09:34:21 wazuh-agent1 sshd[3345]: Accepted password for ag2 from 192.168.130.129 port 33938 ssh2
User: ag2
Aug 10 09:34:21 wazuh-agent1 sshd[3345]: pam_unix(sshd:session): session opened for user ag2 by (uid=0)
```

Figure 10. *Corresponding authentication log entries as viewed during the investigation, confirming session establishment for the ag2 account.*

5. MITRE ATT&CK Technique Mapping

Stage	Technique ID	Technique Name	Detected
Lateral Movement	T1078	Valid Accounts	Yes
Discovery	T1069 / T1082	Permission Groups / System Info Discovery	Partial
Privilege Escalation	T1548.003	Sudo and Sudo Caching	Yes (Rule 5402)
Persistence	T1053.003	Scheduled Task/Job: Cron	Yes (FIM)
Exfiltration	T1041	Exfiltration Over C2 Channel	Partial — see Sec. 7
Defense Evasion	T1070	Indicator Removal	Yes

6. Results and Evaluation

The exercise successfully exercised a complete, multi-stage attack chain against a monitored endpoint and cross-validated the resulting telemetry through both the command-line alert log and the Wazuh dashboard. Out of the six mapped kill-chain stages, five produced clear, attributable detections using Wazuh's default rule set alone, with no custom rule authoring required — notably the SSH authentication event, the privilege escalation via sudo, the file-integrity change on the persistence mechanism, and the log-tampering attempt during defense evasion.

Investigation via the dashboard's Threat Hunting module independently reproduced the same evidence obtained from the raw alert log, confirming that an analyst working purely from the graphical interface — without shell access to the manager — would have been able to reconstruct the same incident timeline.

7. Detection Gaps and Recommendations

One notable limitation was observed during the exfiltration stage: because the file transfer was conducted over SCP (an encrypted SSH-based channel), Wazuh's default detection surfaced only the underlying SSH session rather than any file-transfer-specific indicator. This is an expected and realistic limitation of network- and log-based monitoring against encrypted channels, and mirrors a genuine detection gap present in many production SOC environments.

Recommendations to close this gap include:

- Deploying host-based process monitoring (e.g., auditd rules for scp/sftp invocations) to capture file-transfer activity independent of network encryption.
- Enabling data loss prevention (DLP) tooling or file-access auditing on directories containing sensitive data, so file reads themselves — not just network transfer — generate an alert.
- Extending Wazuh's active response capability to trigger automatic session review or containment when a monitored high-privilege account initiates an outbound SCP/SFTP session shortly after a privilege

escalation event, correlating the two stages automatically rather than relying on manual analyst review.

8. Conclusion

This exercise demonstrated that a self-hosted Wazuh deployment, configured with modest customization beyond its default installation, provides meaningful detection coverage across the majority of a realistic insider-threat kill chain — from initial lateral movement through privilege escalation, persistence, and anti-forensic log tampering. The one identified gap, around encrypted-channel exfiltration, is both realistic and instructive, illustrating the kind of layered-defense reasoning expected of a security engineer: no single control catches everything, and detection engineering is an iterative process of identifying and closing such gaps.

References

- Wazuh Documentation — https://documentation.wazuh.com
- MITRE ATT&CK Framework — https://attack.mitre.org
- DVWA (Damn Vulnerable Web Application) — https://github.com/digininja/DVWA

Appendix A. Sequence Diagram — End-to-End Attack and Detection Flow

The diagram below consolidates every stage of the exercise (Sections 4.1-4.9) into a single sequence view, showing the order of interactions between the attacker machine, the monitored endpoint (wazuh-agent1, acting first as ag2 and then as root after escalation), the Wazuh Manager, and the SOC analyst reviewing the dashboard. Self-referencing arrows represent local actions taken on the endpoint; horizontal arrows represent network traffic or telemetry that Wazuh captured and forwarded for alerting.

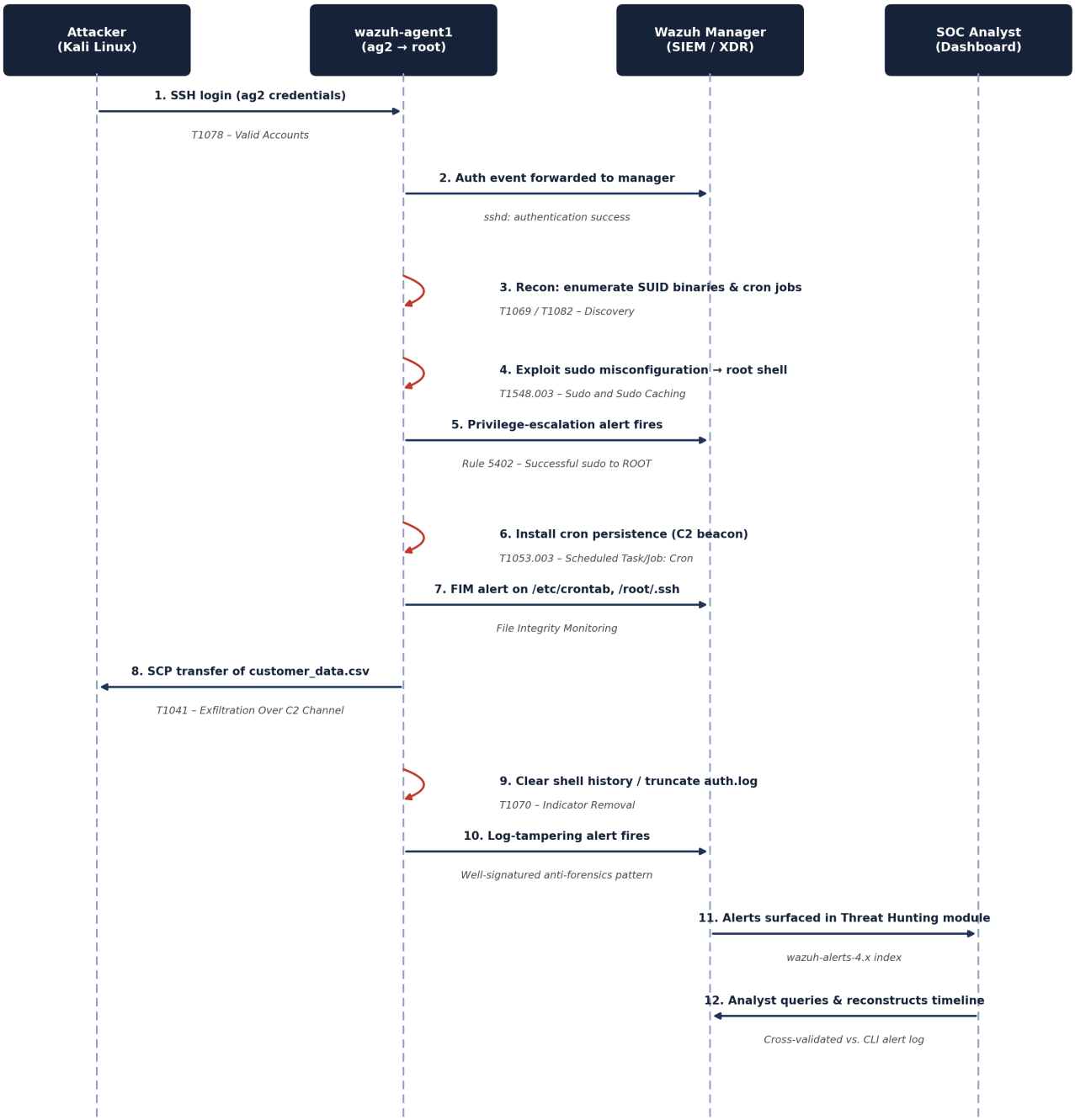


Figure 11. Sequence diagram of the full insider-threat kill chain, from initial SSH access through anti-forensic log tampering, cross-referenced against the corresponding Wazuh detections at each stage.